



Matematički fakultet,
Univerzitet u beogradu

Ofanzivna bezbednost i penetration testing

Autor: Katarina Grbović

Prof. Dr Sana
Stojanović Đurđević

Sadržaj

**Uvod u ofanzivnu
bezbednost**

**Tipovi i metodologije
pentestinga**

Alati i eskalacija privilegija

**Zakonski i etički aspekti,
trendovi i budućnost
ofanzivne bezbednosti**

Uvod u ofanzivnu bezbednost

Šta je to ofanzivna bezbednost i kako se razlikuje u odnosu na defanzivnu bezbednost?



Ofanzivna bezbednost

Ofanzivna bezbednost koristi taktike hakera da poboljša zaštitu sistema. Cilj je otkriti ranjivosti pre nego što ih napadači zloupotrebe.



Ofanzivna i defanzivna bezbednost

Ofanzivna: simulira napade, koristi ih za jačanje sistema.

Defanzivna: detekcija i odgovor na napade (firewall, antivirus).





Šta je pentesting?

Simulacija napada kako bi se otkrile slabosti unutar sistema.

Praktičniji i sveobuhvatniji pregled i uvid u probleme u odnosu na automatske alate.

Metodologije pentestinga

Postoji više različitih metodologija koje se koriste u oblasti pentestinga.

Metodologija	Opis
PTES	Penetration Testing Execution Standard – predstavlja standard od 7 faza.
NIST SP 800-115	Technical Guide to Information Security Testing and Assessment - zvanični standard izdat od strane države.
OSSTMM	Vodi testiranje kroz pet kanala da bi se utvrdilo koliko zaista funkcionišu bezbednosni procesi
OWASP	Definisan od strane OpsSec – definiše standard bezbednosti veb aplikacija.

Faze PTES metodologije

- Priprema i pristanak
- Prikupljanje informacija
- Modelovanje pretnji
- Analiza ranjivosti
- Eksploatacija
- Post-eksploatacija
- Izveštavanje

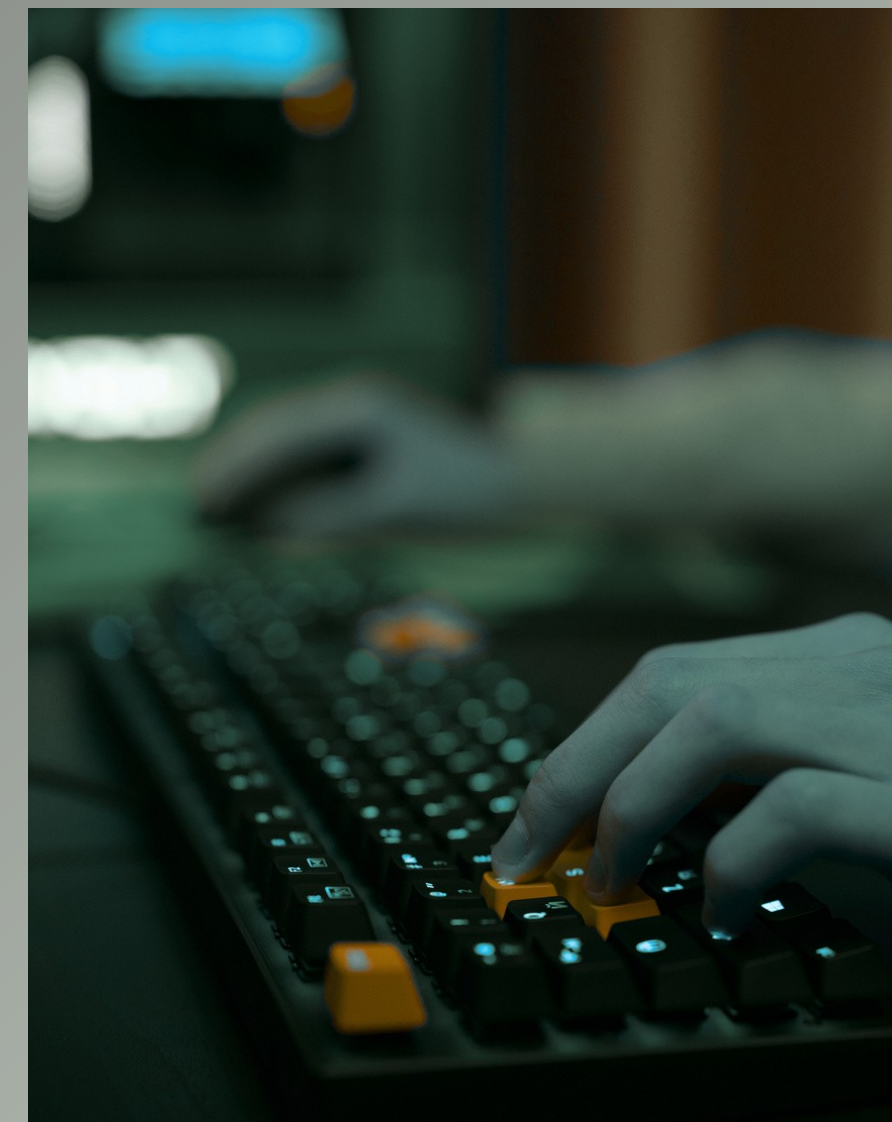
Tipovi pentestinga

- **Prema tipu sistema**
 - Interni/eksterni, mrežni
 - Veb I mobilne aplikacije
 - Cloud, agilni I socijalni inženjering
- **Prema količini dostupnih informacija**
 - White box
 - Gray box
 - Black box

Etika i zakon



**Autorizacija,
poverljivost i
transparentnost**



**Usklađenost sa
zakonima,
dokumentacija**

CEH i OSCP sertifikati

CEH

Etički hakeri (EC-Council)

OSCP

Praktične veštine (OffSec)

Trendovi i budućnost

- Purple teaming – saradnja crvenog i plavog tima
- AI pentesting – sigurnost AI modela i prompt injection

